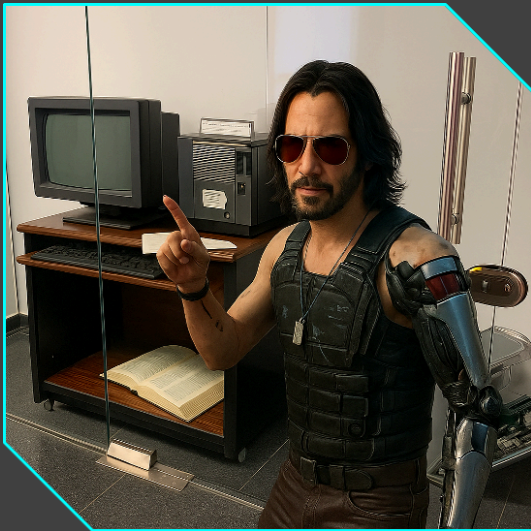


REDES Y SEGURIDAD 2

PRÁCTICA 2.1



JOHNNY: 1990. CERN. Un servidor web tan inocente como una canción sin distorsión. No tenía cifrado, ni certificados, ni paranoias. Sólo un ordenador con una pegatina que decía '¡No apagar! Servidor en producción'. Fue el inicio de todo. Pero esos días se acabaron. Hoy, levantar un servidor sin blindarlo es como caminar por Pacífica

con los bolsillos llenos de edis y una diana en la espalda. Así que vamos a hacer las cosas bien: servidor web, sí... pero con certificado digital, conexión segura y cabeza fría. Porque en esta red, la confianza no se da, se cifra.

En esta práctica aprenderás a:

- Emitir certificados con **XCA**.
- Desplegar un servidor web seguro con Apache.

CHAMBA: P21-https



Las máquinas (**server** y **client**) ya tienen su IP asignada y están listas para trabajar sobre ellas.

CONEXIÓN SIN CIFRAR

SERVER

Crear un usuario y darle una contraseña (recomendado usar el comando **adduser**).

Arrancar el servicio SSH y **apache2** (servidor web) usando el comando **service**.

CLIENT (usando Remmina)

Conectar con el navegador web a **http://server/**.



Si el navegador web devuelve un error de permisos, se deberá ejecutar lo siguiente en **server**:

> **chmod -R 755 /var/www/html**

CLIENT (usando Remmina)

Arrancar la aplicación **XCA**, la cual puede encontrarse en el menú **Aplicaciones** (submenú **Accesorios**).

Para empezar a trabajar será necesario crear una nueva base de datos (menú **Archivo**).

- Se pedirá un nombre de archivo.
- Se deberá introducir una contraseña para protegerla.

CREAR UNA AC RAÍZ

CLIENT (usando Remmina)

Indicar que se quiere emitir un **Nuevo Certificado**.

Elegir como **Plantilla para el nuevo certificado** que se desea la **[default] CA** y pulsar en **Aplicar todo**.

En la pestaña **Sujeto** introducir como nombre interno y nombre común **DelamainCA**, y como nombre de la organización, **Delamain**. Posteriormente, pulsar en **Generar una nueva clave**.

Aparecerá una ventana emergente para revisar las características de la nueva clave. Pulsar en **Crear**.

En la pestaña **Extensiones**, indicar que el tipo es **Autoridad Certificadora**.

Finalmente, pulsar en **Aceptar**.

CREAR UNA SUB-AC

CLIENT (usando Remmina)

Indicar que se quiere emitir un **Nuevo Certificado**.

Verificar que se usará **DelamainCA** para firmar este certificado.

Elegir como **Plantilla para el nuevo certificado** que se desea la **[default] CA** y pulsar en **Aplicar todo**.

En la pestaña **Sujeto** introducir como nombre interno, nombre común y nombre de la unidad organizativa **DelamainWeb**, y como nombre de la organización, **Delamain**. Posteriormente, pulsar en **Generar una nueva clave**.

Aparecerá una ventana emergente para revisar las características de la nueva clave. Pulsar en **Crear**.

En la pestaña **Extensiones**, indicar que el tipo es **Autoridad Certificadora**.

CLIENT (usando Remmina)

Finalmente, pulsar en **Aceptar**. Aparecerá un diálogo indicando una discrepancia con las fechas de caducidad. Se recomienda elegir la opción en la que **XCA** las ajuste.

CREAR EL CERTIFICADO DE HOST

CLIENT (usando Remmina)

Indicar que se quiere emitir un **Nuevo Certificado**.

Verificar que se usará **DelamainWeb** para firmar este certificado.

Elegir como **Plantilla para el nuevo certificado** que se desea la **[default] TLS_server** y pulsar en **Aplicar todo**.

En la pestaña **Sujeto** introducir como nombre interno y nombre común **server**, y como nombre de la organización, **Delamain**.

Posteriormente, pulsar en **Generar una nueva clave**.

Aparecerá una ventana emergente para revisar las características de la nueva clave. Pulsar en **Crear**.

En la pestaña **Extensiones**, indicar que el tipo es **Entidad final**.

CLIENT (usando Remmina)

Finalmente, pulsar en **Aceptar**. Aparecerá un diálogo indicando una discrepancia con las fechas de caducidad. Se recomienda elegir la opción en la que **XCA** las ajuste.

EXPORTAR CERTIFICADOS Y CLAVES

CLIENT (usando Remmina)

En la pestaña de **Certificados** se indicará que se desea **Exportar**. El formato elegido es **PEM (*.crt)**.

Hacer una segunda exportación en la misma pestaña, pero ahora con el formato **PEM Chain (*.pem)**, que almacena la cadena de Autoridades de Certificación hasta la raíz. Se recomienda añadir la palabra **cachain** al nombre del archivo, con el objetivo de poder diferenciarlos más adelante.

En la pestaña **Claves Privadas** se indicará que se desea **Exportar**. El formato elegido es **PEM private (*.pem)**.

SUBIR LOS ARCHIVOS AL SERVIDOR

CLIENT (usando Remmina)

Copiar los archivos generados al directorio **/tmp** de **server**. Se recomienda usar **scp**.

CONFIGURAR HTTPS EN APACHE

SERVER

Copiar los archivos que se han transferido al directorio **/tmp** en el paso anterior al directorio **/etc/apache2**.

Arrancar el módulo SSL de Apache.

> **a2enmod ssl**

Reiniciar **apache2** con el comando **service**.

Editar un nuevo fichero de configuración en **/etc/apache2/sites-available/server.conf**

En el siguiente listado se asume que:

- El certificado del servidor es **server.crt**.

SERVER

- La clave está en **server.pem**.
- El fichero de cadena de CAs es **server-cachain.pem**.

```
<VirtualHost *:443>
```

```
    ServerAdmin webmaster@Delamain
```

```
    DocumentRoot /var/www/html
```

```
    ServerName server
```

```
    SSLEngine on
```

```
    SSLCertificateFile /etc/apache2/server.crt
```

```
    SSLCertificateKeyFile /etc/apache2/server.pem
```

```
    SSLCertificateChainFile /etc/apache2/server-cachain.pem
```

```
<Directory /var/www/html>
```

```
    Options Indexes FollowSymLinks
```

```
    AllowOverride None
```

```
    Require all granted
```

```
</Directory>
```

```
    ErrorLog ${APACHE_LOG_DIR}/error.log
```

```
    CustomLog ${APACHE_LOG_DIR}/access.log combined
```

```
</VirtualHost>
```

SERVER

Añadir el sitio creado al servidor web.

> **a2ensite server.conf**

Reiniciar el servicio **apache2** con el comando **service** y comprobar que no devuelve ningún error.

PRIMER ACCESO A HTTPS

CLIENT (usando Remmina)

Acceder con el navegador web a **https://server/**.

Comprobar que se obtiene un error de riesgo potencial para la seguridad.



¿A qué código de error está respondiendo el navegador web?

¿Qué lo ha provocado?

CONFIAR EN LA AC RAÍZ

CLIENT (usando Remmina)

Volver a **XCA**. Seleccionar el certificado de la AC raíz (**DelamainCA**) y pulsar en **Exportar**. El formato elegido será **PEM (*.crt)**.

En el navegador web, entrar en **Ajustes** y desde ahí, buscar la sección de **Certificados**. Pinchar en **Ver certificados**, y en la pestaña de **Autoridades** se seleccionará la opción de **Importar**.

Se deberá seleccionar el certificado de **DelamainCA** previamente exportado y se indicará que se desea confiar en esta AC para sitios web. Confirmar que se ha añadido a la lista.

Volver a acceder con el navegador web a **<https://server/>**.



¿Por qué confía en un certificado emitido por **DelamainWeb** si el certificado de AC importado es de **DelamainCA**?

¿Cuál es el mensaje de aviso que el navegador web devuelve a pesar de lo anterior?



Delamain es un tío majo pero no podemos ser "legal bueno" siempre. Investiga formas de desplegar una puerta trasera en el servidor web y lleva a cabo el plan.

Algunas ideas:

- https://github.com/VladRico/apache2_BackdoorMod
- <https://github.com/WangYihang/Apache-HTTP-Server-Module-Backdoor>

Esto requerirá de la instalación de paquetes extra en **server**.